

QA Security Report — базовый аудит (A6)

Дата: 2026-07-30. Ветка: v1.1.0 → v2.0.0-dev. Метод: код-ревью + автотесты
(tests/test_negative.py).

Найдено и исправлено кодом

#	Проблема	Статус	Фикс
SEC-1	IDOR: GET /api/quotes/?request_id= возвращал КП чужих заявок любому авторизованному пользователю	☐ Замкнуто	QuoteViewSet.get_queryset всегда ограничен request__customer=request.user
SEC-2	IDOR: GET /api/quotes/competitive_sheet/?request_id= показывал конкурентный лист чужой заявки; несуществующий id ронял запрос с 500 (FK violation)	☐ Замкнуто	Проверка владения заявкой, 404 для чужой/несуществующей
SEC-3	XSS в email-HTML: item.name, supplier.name, address подставлялись в HTML-письмо без экранирования (<script> в названии позиции исполнялся бы в почтовом клиенте)	☐ Замкнуто	html.escape() в build_rfq_email; LLM-письма рендерятся через text_to_html с экранированием
SEC-4	public_quote POST принимал цену 0 / отрицательную / нечисловую и пустой список позиций	☐ Замкнуто	Валидация → 400; тесты: test_post_price_zero_400, test_post_negative_price_400, test_post_without_items_400

Проверено — проблем нет

- **Перебор токенов /quote/{token}:** токен 64 символа urlsafe (256 бит энтропии), throttle 30/мин — 31-й запрос → 429 (тест test_throttle_429_after_30).
- **Утечка данных заказчика:** публичный ответ /api/public/quote/ не содержит email/телефона заказчика (тест test_no_customer_data_leak).
- **IDOR в RequestViewSet:** все action'ы идут через get_queryset() с фильтром customer=user; чужая заявка → 404 (тест test_parse_other_users_request_404).

- **SQLi:** весь доступ к БД через ORM; `raw_text = '' OR 1=1--` сохраняется как строка (тест `test_sqli_in_raw_text`).
- **XSS в React:** `raw_text` с `<script>` хранится дословно, React экранирует при рендере (тест `test_xss_in_raw_text_stored_literally`).
- **CORS:** dev — только `localhost:3000/127.0.0.1:3000`; prod — только домены минитендер.рф из `CORS_ALLOWED_ORIGINS`.
- **DEBUG:** `DEBUG=False` в base и prod; `SECRET_KEY` в prod берётся из env (без default).
- **Webhook inbound:** проверка HMAC-подписи Mailgun при наличии `INBOUND_EMAIL_WEBHOOK_SECRET`.
- **LLM-письма:** запрещённые формулировки и провокационные входные помечаются `needs_review` и НЕ отправляются (B9, eval-тесты).

Открытые замечания (не критичные)

#	Замечание	Рекомендация
SEC-5	<code>SECRET_KEY="dev-secret-key"</code> хардкодом в <code>base.py</code> (используется только dev/test)	Вынести в env с dev-default; prod уже требует env
SEC-6	JWT access-токен 1ч, refresh 14 дней, blacklist не включён при logout	Включить <code>token_blacklist</code> при необходимости принудительного logout
SEC-7	Rate limiting только на публичном <code>/quote/</code> ; <code>/api/auth/login/</code> без throttle	Добавить throttle на login (защита от брутфорса пароля)
SEC-8	Загрузка файлов отсутствует — поверхность атаки минимальна	При добавлении upload'ов — антивирус/лимиты